

แบบเสนอหัวข้อโครงการ (สหกิจศึกษา)

1. หัวข้อรายงาน

ภาษาไทย: การพัฒนาเครื่องมือรวบรวมข้อมูลเชิงกำหนดแน่นอนและระบบสร้างรายงานตาม Checklist สำหรับการทดสอบเจาะระบบเว็บแอปพลิเคชัน

ภาษาอังกฤษ: Deterministic Enumeration and Checklist-Driven Reporting for Web Application Penetration Testing

2. หลักการและเหตุผล

ในการทดสอบเจาะระบบ (penetration testing) เว็บแอปพลิเคชัน

ขั้นตอนแรกสำหรับผู้ทดสอบทุกคนต้องดำเนินการคือขั้นตอนการสำรวจพื้นผิวการโจมตี หรือที่เรียกว่า enumeration

ซึ่งครอบคลุมตั้งแต่การตรวจสอบพอร์ตและบริการที่เปิดอยู่ การค้นหาไดเรกทอรีและ endpoint ที่ซ่อนอยู่

การระบุเทคโนโลยีที่ระบบใช้งาน ไปจนถึงการตรวจสอบการตั้งค่าความปลอดภัยเบื้องต้น เช่น security header

และการตั้งค่า TLS จากประสบการณ์ตรงของผู้จัดทำที่ได้ผ่านการฝึกงานด้านนี้มา

พบว่าขั้นตอนดังกล่าวมักใช้เวลาในกระบวนการทดสอบทั้งหมด

ทั้งที่เป็นงานที่มีรูปแบบซ้ำเดิมและไม่จำเป็นต้องอาศัยการตัดสินใจเชิงลึกมากเท่ากับขั้นตอนการวิเคราะห์และยืนยันช่องโหว่

ปัญหานี้เกิดจากการที่ผู้ทดสอบต้องสลับใช้เครื่องมือหลายตัวแยกจากกัน

แล้วนำผลลัพธ์จากแต่ละเครื่องมือมารวบรวมและเรียบเรียงด้วยมือ

ส่งผลให้เสียเวลาไปกับงานที่ไม่ใช่แก่นของการวิเคราะห์จริง

ที่ผ่านมาความพยายามแก้ปัญหาจากหลายแนวทาง ทั้งในรูปแบบซอฟต์แวร์เชิงพาณิชย์ที่ให้บริการผ่านระบบคลาวด์

และเครื่องมือที่นำปัญญาประดิษฐ์ในลักษณะ agent เข้ามาช่วยตัดสินใจว่าจะทดสอบสิ่งใดต่อในแต่ละขั้นตอน อย่างไรก็ตาม

แนวทางทั้งสองยังมีข้อจำกัดสำคัญเมื่อนำมาใช้ในการทดสอบระบบที่มีความอ่อนไหวสูง เช่น ระบบธนาคารหรือระบบการเงิน

กล่าวคือ เครื่องมือที่พึ่งพาระบบคลาวด์ทำให้ข้อมูลของเป้าหมายต้องถูกส่งออกนอกเครือข่ายที่ควบคุมได้

ซึ่งขัดกับข้อกำหนดด้านการรักษาความลับของงานลักษณะนี้ ในขณะที่เครื่องมือที่ใช้ปัญญาประดิษฐ์ตัดสินใจในขั้นตอน

enumeration โดยตรงนั้น แม้จะดูสะดวกในเบื้องต้น แต่ผลลัพธ์ที่ได้ไม่สามารถรับประกันความสม่ำเสมอได้ทุกครั้งที่รันซ้ำ

อีกทั้งยังมีต้นทุนด้านการประมวลผลที่สูงขึ้นตามขนาดของเป้าหมาย

และมีความเสี่ยงที่ไม่เคลจะสร้างข้อมูลที่คลาดเคลื่อนจากความเป็นจริง

ซึ่งเป็นความเสี่ยงที่ยอมรับไม่ได้ในงานที่ผลลัพธ์ต้องนำไปใช้อ้างอิงในลักษณะที่ตรวจสอบย้อนกลับได้

จากข้อจำกัดดังกล่าว โครงการนี้จึงมุ่งพัฒนาเครื่องมือที่รวมขั้นตอน enumeration ของเว็บแอปพลิเคชันไว้ในจุดเดียว

โดยยึดหลักการให้ขั้นตอนการเก็บข้อมูลทั้งหมดทำงานผ่านการเรียกใช้เครื่องมือมาตรฐานโดยตรงแบบกำหนดแน่นอน

โดยไม่มีปัญญาประดิษฐ์เข้ามาเกี่ยวข้องในขั้นตอนนี้ เพื่อให้ผลลัพธ์ที่ได้สามารถทำซ้ำได้และตรวจสอบย้อนกลับได้เสมอ

ควบคู่ไปกับการสร้างระบบ checklist ที่ช่วยให้ผู้ทดสอบทราบหัวข้อใดได้ทดสอบไปแล้วหรือยัง

และระบบสร้างรายงานที่ช่วยลดภาระงานด้านเอกสาร ซึ่งเป็นอีกขั้นตอนหนึ่งที่ใช้เวลามากในกระบวนการทดสอบทั้งหมด

3. วัตถุประสงค์

3.1 เพื่อพัฒนาเครื่องมือแบบ terminal-native ที่รวมการทำงานของเครื่องมือ enumeration สำหรับเว็บแอปพลิเคชันไว้ในจุดเดียว พร้อมระบบ checklist ที่อ้างอิงมาตรฐาน OWASP Web Security Testing Guide (WSTG) สำหรับติดตามสถานะการทดสอบ

3.2

เพื่อพัฒนาโมดูลสร้างรายงานที่แปลงผลลัพธ์จากการทดสอบให้อยู่ในรูปแบบที่นำไปปรับใช้กับรายงานของแต่ละหน่วยงานได้ โดยมีข้อมูลอ้างอิงที่เป็นประโยชน์ต่อผู้ทดสอบ เช่น evidence, OWASP category, CVSS score และ CWE ID

3.3 เพื่อให้กระบวนการ enumeration ทั้งหมดทำงานแบบกำหนดแน่นอนและสามารถทำงานแบบ offline ได้อย่างสมบูรณ์ โดยไม่ต้องพึ่งพาปัญหาประติษฐ์หรือบริการคลาวด์ภายนอก เพื่อให้เหมาะสมกับการทดสอบระบบที่มีความอ่อนไหวสูง

4. ขอบเขตการศึกษา

โครงการนี้ครอบคลุมเฉพาะการทดสอบเจาะระบบเว็บแอปพลิเคชัน (HTTP/HTTPS) เท่านั้น ไม่ครอบคลุมการทดสอบ network infrastructure, Active Directory, wireless หรือ mobile application เครื่องมือที่พัฒนาทำหน้าที่ enumerate และรวบรวมหลักฐานเท่านั้น โดยไม่มีการ exploit ช่องโหว่แบบอัตโนมัติ การยืนยันช่องโหว่ยังคงเป็นหน้าที่ของผู้ทดสอบ และโครงการนี้เป็นการพัฒนาขั้น orchestration ที่เรียกใช้เครื่องมือ open-source ที่มีอยู่แล้ว ไม่ได้พัฒนา scanner หรือ exploit ขึ้นใหม่ตั้งแต่ต้น ผลลัพธ์สุดท้ายของโครงการคือระบบ checklist ที่อ้างอิง OWASP WSTG หมวด Information Gathering และ Configuration Management พร้อมระบบ export รายงานเป็นไฟล์ Word (.docx) และ Markdown

5. ความรู้พื้นฐานและเครื่องมือที่ใช้

ความรู้พื้นฐานที่จำเป็น ได้แก่ มาตรฐาน OWASP Web Security Testing Guide (WSTG) สำหรับออกแบบ checklist, ระบบการให้คะแนนความรุนแรงของช่องโหว่ CVSS (Common Vulnerability Scoring System) และการจัดหมวดหมู่ช่องโหว่ CWE (Common Weakness Enumeration) สำหรับการ mapping ข้อมูลลงรายงาน, พื้นฐานการเขียนโปรแกรมภาษา Python โดยเฉพาะการจัดการ subprocess และการ parse ข้อมูล, และพื้นฐานการออกแบบ Terminal User Interface (TUI)

เครื่องมือ enumeration ที่นำมาใช้ แบ่งตามหมวดการทำงาน ดังตาราง:

หมวดหมู่	เครื่องมือ	หน้าที่
Asset & Subdomain Discovery	subfinder, amass (passive), dnsx	ค้นหา subdomain และ asset ที่เกี่ยวข้องกับ target
Host & Port Enumeration	nmap	ตรวจสอบพอร์ตเปิดและระบุ service/version
HTTP Probing & Screenshot	httpx, gowitness/aquatone	ตรวจสอบว่า host ใดตอบสนอง HTTP และเก็บภาพหน้าจอเบื้องต้น
Content & Endpoint Discovery	ffuf/gobuster, katana	ค้นหา directory, file และ endpoint จากการ brute-force และ crawl JS/HTML
Technology & CMS Fingerprinting	whatweb, wappalyzer-cli, wpscan	ระบุ technology stack และตรวจสอบ CMS เฉพาะทาง (เช่น WordPress)
TLS & Header Analysis	testssl.sh, security header checker	ตรวจสอบ TLS posture และ security header (HSTS, CSP, X-Frame-Options ฯลฯ)

Vulnerability Signature Scanning	nikto, nuclei	สแกนหา signature ของช่องโหว่ที่รู้จักแล้วผ่าน template-based scanning (ยังกำหนดแน่นอน ไม่ใช่ AI-driven)
Parameter & API Discovery	arjun, GraphQL/REST endpoint checker	ค้นหา hidden parameter และ endpoint ของ API
WAF Detection	wafw00f	ตรวจสอบว่า target มี WAF ปกป้องกันอยู่หรือไม่

เทคโนโลยีสำหรับพัฒนาระบบ: Python (ภาษาหลัก), Textual (framework สำหรับ Terminal UI), SQLite (จัดเก็บ engagement state), python-docx (สร้างรายงาน Word)

6. แผนการดำเนินงาน

ระยะที่ 1: การทบทวนวรรณกรรมและมาตรฐานที่เกี่ยวข้อง

ศึกษาและทบทวนมาตรฐาน OWASP Web Security Testing Guide (WSTG) เพื่อใช้เป็นกรอบอ้างอิงในการออกแบบ checklist รวมถึงศึกษาระบบการให้คะแนนความรุนแรงของช่องโหว่ Common Vulnerability Scoring System (CVSS) และระบบจำแนกประเภทช่องโหว่ Common Weakness Enumeration (CWE) เพื่อนำมาใช้ในการออกแบบโครงสร้างรายงาน

ระยะที่ 2: การศึกษาและคัดเลือกเครื่องมือ

ศึกษาความสามารถและข้อจำกัดของเครื่องมือ enumeration แบบ open-source ในแต่ละหมวดการทำงาน ได้แก่ การค้นหา subdomain (subfinder, amass, dnsx) การตรวจสอบพอร์ตและบริการ (nmap) การตรวจสอบการตอบสนอง HTTP (httpx, gowitness) การค้นหา endpoint (ffuf, gobuster, katana) การระบุเทคโนโลยี (whatweb, wappalyzer-cli, wpscan) การวิเคราะห์ TLS (testssl.sh) การสแกนหาช่องโหว่ที่ทราบแล้ว (nikto, nuclei) การค้นหาพารามิเตอร์ (arjun) และการตรวจจับ WAF (wafw00f) เพื่อคัดเลือกเครื่องมือที่เหมาะสมสำหรับนำมาบูรณาการเข้ากับระบบ

ระยะที่ 3: การออกแบบสถาปัตยกรรมระบบและโครงสร้างข้อมูลกลาง

ออกแบบโครงสร้างข้อมูลกลาง (unified schema) ที่ใช้รองรับผลลัพธ์จากเครื่องมือทั้งหมดในรูปแบบเดียวกัน เพื่อให้ระบบสามารถประมวลผลและเชื่อมโยงข้อมูลระหว่างเครื่องมือได้อย่างสอดคล้อง

ระยะที่ 4: การพัฒนาขั้น Tool Orchestration

พัฒนา wrapper สำหรับเรียกใช้เครื่องมือภายนอกผ่าน subprocess พร้อมกลไก parser ที่แปลงผลลัพธ์ดิบจากแต่ละเครื่องมือให้อยู่ในรูปแบบโครงสร้างข้อมูลที่กำหนดไว้

ระยะที่ 5: การพัฒนา Checklist และ State Engine

พัฒนาระบบจับคู่ระหว่างรายการใน OWASP WSTG กับเครื่องมือที่เกี่ยวข้อง พร้อมพัฒนา Terminal User Interface ด้วย Textual framework เพื่อให้ผู้ใช้งานติดตามสถานะการทดสอบและบันทึก finding ที่ตรวจพบด้วยตนเองได้

ระยะที่ 6: การพัฒนา Reporting Engine

พัฒนาระบบคำนวณคะแนน CVSS และการ mapping CWE/OWASP โดยอัตโนมัติ พร้อมพัฒนา template engine สำหรับสร้างรายงานในรูปแบบไฟล์ .docx และ .md ที่สามารถปรับโครงสร้างให้สอดคล้องกับรูปแบบรายงานของแต่ละหน่วยงานได้

ระยะที่ 7: การทดสอบระบบ

ทดสอบระบบกับเป้าหมายจริงในสภาพแวดล้อมจำลอง (HackTheBox, internal lab) เพื่อประเมินความครบถ้วนของ checklist coverage และความสม่ำเสมอของผลลัพธ์เมื่อทำการทดสอบซ้ำ (reproducibility)

ระยะที่ 8: การสรุปผลและจัดทำเอกสาร

ปรับปรุงแก้ไขข้อบกพร่องที่พบจากการทดสอบ จัดทำเอกสารทางเทคนิคและคู่มือการใช้งาน พร้อมเตรียมเนื้อหาสำหรับการนำเสนอโครงการ

7. ประโยชน์ที่คาดว่าจะได้รับ

7.1 ได้เครื่องมือ CLI/TUI ที่ใช้งานได้จริงสำหรับการทำ enumeration เว็บแอปพลิเคชันแบบ checklist-driven ซึ่งช่วยลดภาระในการสลับใช้เครื่องมือหลายตัวแยกกัน

7.2 ได้ระบบสร้างรายงานต้นแบบที่ generate อัตโนมัติ พร้อมข้อมูลอ้างอิง OWASP/CVSS/CWE ที่นำไปปรับใช้กับรูปแบบรายงานของหน่วยงานต่าง ๆ ได้

7.3 ได้เอกสารทางเทคนิคและคู่มือการใช้งานที่สามารถนำไปต่อยอดใช้งานจริงในทีมทดสอบเจาะระบบ

จึงเรียนมาเพื่อโปรดทราบ